UNIVERSITI TEKNOLOGI MARA
FINAL EXAMINATION

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

INSTRUCTIONS TO CANDIDATES

1. This question paper consists of two (2) parts: PART A (10 Questions)
   PART B (2 Questions)

2. Answer ALL questions in the Answer Booklet. Start each answer on a new page.

3. Do not bring any material into the examination room unless permission is given by the invigilator.

4. Please check to make sure that this examination pack consists of:

   i) the Question Paper
   ii) an Answer Booklet - provided by the Faculty

5. Answer ALL questions in English.

DO NOT TURN THIS PAGE UNTIL YOU ARE TOLD TO DO SO

This examination paper consists of 5 printed pages

© Hak Cipta Universiti Teknologi MARA

PART A (80 MARKS)

QUESTION 1

a) State TWO (2) characteristics of a Trojan horse as a type of malware.

(2 marks)

b) State SIX (6) techniques by which malware propagates or conceals itself within an infected system, as described in the lecture on software security.

(6 marks)

QUESTION 2

a) Explain the difference between morals, ethics and laws as three distinct forms of guidance for professional conduct.

(2 marks)

b) Discuss how a professional code of ethics and conduct guides a computer security practitioner, referring to the ACM code and the professional conduct expected of computing professionals. Support your discussion with six distinct requirements.

(6 marks)

QUESTION 3

a) State TWO (2) ethical responsibilities that information specialists carry when working with ICT, according to the discussion of moral and ethical dimensions.

(2 marks)

b) Explain six (6) points about how an organisation's ethical code shapes professional conduct and responsibility, including what the code adds, how it guides staff, and what consequences may follow when it is not followed.

(6 marks)

QUESTION 4

a) Explain how a chain of trust is established in the Trusted Computing architecture, referring to the role of the TPM and the roots of trust.

(2 marks)

b) Describe six components and characteristics of the Next Generation Secure Computing Base (NGSCB), focusing on the Nexus and the Nexus Computing Agent (NCA).

(6 marks)

QUESTION 5

a) State TWO (2) rules that govern access under the Chinese Wall model.

(2 marks)

© Hak Cipta Universiti Teknologi MARA

a) Describe the access control matrix, the access control list and the capability list as access control structures, giving one advantage and one disadvantage of the access control matrix and of the access control list, and stating what a capability list associates with each subject.

(6 marks)

QUESTION 6

a) List TWO (2) reasons why software is insecure, as discussed in the Software Security lecture.

(2 marks)

b) Compare the security mechanisms available in Windows with those available in UNIX, focusing on the strengths and weaknesses of each. Provide six (6) distinct points of comparison.

(6 marks)

QUESTION 7

a) A company is deploying a Network-Based Intrusion Detection System (NIDS) to protect its critical servers. List TWO (2) typical locations where IDS sensors should be placed.

(2 marks)

b) Discuss the preventive network security mechanisms that an organization can deploy to control and protect its network traffic, and explain how these mechanisms relate to intrusion detection. Support your discussion with six distinct points.

(6 marks)

QUESTION 8

a) Explain how the disclosure and disruption classes of threats each affect the confidentiality, integrity and availability of information assets.

(2 marks)

b) Refer to your answer in (a). The Samy worm spread through MySpace by exploiting a cross-site scripting flaw. Explain six distinct steps or effects of this worm as described in the lecture, covering how it injected code, gathered data, added friends, propagated to visitors, and the scale of infection.

(6 marks)

QUESTION 9

a) Explain two ways in which an intrusion detection system contributes to detecting and defending against attacks on computer systems.

(2 marks)

© Hak Cipta Universiti Teknologi MARA

b) State six distinct points from the lecture that characterise threat classes and the countermeasures used against them, covering how threats differ from vulnerabilities and attacks, how web attacks such as XSS and SQL injection operate, and how protection mechanisms such as sandboxing and input sanitisation respond to these threats.

(6 marks)

QUESTION 10

a) Explain the two stages of the biometric authentication process and state what happens during each stage.

(2 marks)

b) Explain six points about biometric mechanisms and technologies, covering how a biometric is defined, the categories of biometric applications, and the characteristics and drawbacks of specific biometric technologies.

(6 marks)

PART B (20 MARKS)

QUESTION 1

A hospital group runs a shared clinical information system. Doctors and nurses request access to patient records, and the system must decide which subjects may reach which objects and in what way, while an administrator worries about how access decisions are enforced and how the underlying access structures scale.

a) Explain the goals that access control pursues and the role of the reference monitor in making authorization decisions, and describe the access control structures used to implement policies together with the requirements they must satisfy.

(5 marks)

b) Discuss how formal security models address the hospital group's need to control access to patient records, referring to the Chinese Wall model's treatment of conflicts of interest, its dynamic permissions, and the role of past access history, and explain how the BLP and Biba models differ in what they verify.

(5 marks)

QUESTION 2

a) State five password security controls that can be applied to protect a system's password files and accounts, as covered in the lecture on identification and authentication.

(5 marks)

© Hak Cipta Universiti Teknologi MARA

b) A campus network wants users to log in once and reach many servers without retyping passwords. Explain five points about single sign-on and Kerberos that the network designers should consider, covering the motivation for single sign-on, the authentication categories involved, Kerberos design criteria, the initial user authentication exchange, and the limitations of Kerberos.

(5 marks)

END OF QUESTION PAPER

© Hak Cipta Universiti Teknologi MARA